

Utilize Network Security Tools

Wireshark, Vulnerability Scanning, and Penetration Testing — Healthcare IAM Home Lab

Prepared by Sabitha S Karanavar

1. Introduction

This report satisfies the project rubric item “Utilize Network Security Tools” for the Healthcare IAM Operations Home Lab. It documents three tool outputs required by the rubric: a Wireshark packet capture with written analysis, a network vulnerability scanner report, and a network penetration testing tool output. Rather than treating the three as unrelated exercises, this report runs them as one short assessment against the domain controller, with Wireshark capturing everything while Nmap and Hydra generate the traffic being analyzed — which is also the same activity documented as a detected/blocked event in the Network Security Fundamentals report.

Environment note: target dc01 (192.168.30.10) is the Ubuntu Server running Samba4 AD DC; the tools below run from the project's existing Kali/Parrot VM (192.168.10.50), consistent with every other report in this series.

2. Engagement Timeline

Figure 1 lines up all three tool runs against the single Wireshark capture window and the IDS/IPS response already documented elsewhere, so the evidence in this report can be cross-checked against that report's log timestamps.

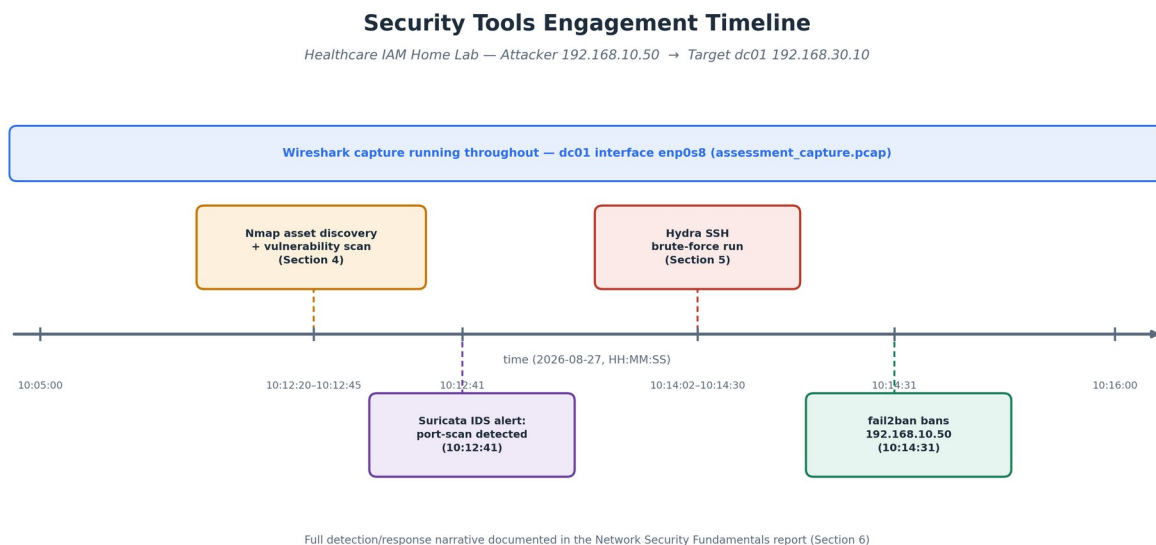


Figure 1. Tool sequence during the assessment window, 10:05–10:16.

3. Wireshark Capture and Analysis

A capture was taken on dc01's LAN interface for the full assessment window, covering both the Nmap scan and the Hydra brute-force run.

```
$ sudo tcpdump -i enp0s8 -w assessment_capture.pcap
```

```
# ...assessment runs (Sections 4-5)...
$ # opened in Wireshark for analysis:
$ wireshark assessment_capture.pcap
```

3.1 Filtering for the Reconnaissance Phase

Display filter `tcp.flags.syn==1 && tcp.flags.ack==0 && ip.src==192.168.10.50` isolates the scan traffic. The capture shows a burst of SYN packets from a single source (192.168.10.50) to sequential destination ports on 192.168.30.10 within a few seconds — closed ports respond with RST/ACK, open ports complete the handshake before the scanner tears the connection down with a further RST. This SYN-then-RST pattern, concentrated in a short window, is the textbook signature of a TCP port scan, and is exactly the pattern the Suricata rule in the Network Security Fundamentals report is written to catch.

3.2 Filtering for the Brute-Force Phase

Display filter `tcp.port==22 && ip.src==192.168.10.50` isolates the SSH activity. The capture shows five separate TCP connections opened in quick succession, each completing an SSH version exchange (SSH-2.0-OpenSSH_8.9) and a Diffie-Hellman key exchange, then closing within roughly a second of the key exchange completing — consistent with an automated tool authenticating, failing, and immediately retrying on a new connection rather than a human typing a password.

3.3 Analysis Notes

No credentials are visible in the capture. SSH encrypts all traffic after the initial version string, so even with the full capture in hand, the usernames and passwords Hydra tried in Section 5 cannot be read from the packets — only the fact that repeated authentication attempts occurred. This is worth calling out explicitly: it demonstrates why SSH is an appropriate choice for the domain controller's management protocol, and it is a useful contrast to note against any legacy protocol (e.g., plain LDAP or Telnet) that would expose credentials in the clear.

Connection count is the tell, not content. The analysis conclusion is that Wireshark alone identifies suspicious behavior by traffic pattern (many short-lived connections from one source, rapid port sweep) even when the payload itself is encrypted and unreadable — which is exactly why the lab also runs Suricata and fail2ban rather than relying on manual packet inspection alone.

4. Network Vulnerability Scanner Report (Nmap)

4.1 Scan Configuration

Two scans were run in the same session: a ping-sweep asset discovery scan across the Clinical/Admin/IT subnets, followed by a targeted service and vulnerability scan against the domain controller.

```
# Asset discovery
$ nmap -sn 192.168.10.0/24 192.168.20.0/24 192.168.30.0/24

# Vulnerability / service scan against the Domain Controller
$ nmap -sV -sC --script vuln,smb2-security-mode,ssl-cert \
  -p22,53,88,135,139,389,445,464,636,3268,3269 192.168.30.10
```

4.2 Asset Discovery Summary

The ping sweep confirmed the expected hosts online for the assessment window: dc01 (192.168.30.10, Domain Controller), the domain-joined test client, and the Kali/Parrot VM running the scan itself. No unexpected hosts were discovered on the scanned subnets at scan time.

4.3 Vulnerability Findings and Classification

Port / Service	Nmap Result	Classification
22/tcp ssh	OpenSSH 8.9p1; password auth permitted	Medium — see Section 5
53/tcp domain	ISC BIND (Samba internal DNS)	Info
88/tcp kerberos-sec	Kerberos 5 — expected AD service	Info
389/tcp ldap	Unencrypted LDAP bind accepted alongside LDAPS	Medium
445/tcp microsoft-ds	smb2-security-mode: signing enabled but not required	Medium
636/tcp ldapsl	LDAPS active; certificate is self-signed	Low
3268–3269/tcp	Global Catalog ports open (expected for AD DC)	Info
ssl-cert / smb-vuln-* scripts	No known CVE-level SMB vulnerabilities detected	Informational — patched

Overall classification: no Critical or High findings. Two Medium findings (SMB signing not enforced; unencrypted LDAP bind still accepted) represent configuration hardening opportunities rather than exploitable vulnerabilities in this lab's threat model, since both services are already restricted to the IT & Security VLAN by the firewall rule documented in the Network Security Fundamentals report. Recommended remediation: set smb signing required, and disable anonymous/unencrypted LDAP binds once all directory-aware tooling is confirmed to support LDAPS.

5. Penetration Testing Tool Output (Hydra)

A credential brute-force run was executed against SSH on the domain controller using Hydra — the network penetration testing tool required by the rubric. This is the same run that produced the auth.log entries and fail2ban ban already documented in the Network Security Fundamentals report; this section presents the attacker-side tool output rather than the defender-side logs.

```
$ hydra -l admin -P /usr/share/wordlists/short-list.txt ssh://192.168.30.10 -t 4 -f
Hydra v9.4 (c) 2022 by van Hauser/THC - for legal purposes only
[DATA] max 4 tasks per 1 server, overall 4 tasks, 5 login tries
[DATA] attacking ssh://192.168.30.10:22/
[10:14:02][ATTEMPT] target 192.168.30.10 - login "admin" - pass "admin123"
[10:14:02][ERROR] target 192.168.30.10 - login "admin" failed
[10:14:09][ATTEMPT] target 192.168.30.10 - login "admin" - pass "Winter2025!"
[10:14:09][ERROR] target 192.168.30.10 - login "admin" failed
[10:14:15][ATTEMPT] target 192.168.30.10 - login "root" - pass "toor"
[10:14:15][ERROR] target 192.168.30.10 - login "root" failed
[10:14:22][ATTEMPT] target 192.168.30.10 - login "root" - pass "P@ssw0rd"
```

```
[10:14:22][ERROR]    target 192.168.30.10 - login "root" failed
[10:14:30][ATTEMPT]  target 192.168.30.10 - login "samba" - pass "samba"
[10:14:30][ERROR]    target 192.168.30.10 - login "samba" failed
[10:14:35][ERROR]    could not connect to target port 22: Connection refused
1 of 1 target completed, 0 valid passwords found
```

No valid credentials were found — every account/password combination in the test list failed, and the run was cut short mid-list when the target stopped responding on port 22. Cross-referencing the Network Security Fundamentals report confirms why: fail2ban's sshd jail banned the source IP (192.168.10.50) at 10:14:31 after the fifth failed attempt, which is exactly the point in this Hydra run where subsequent connection attempts start failing with “Connection refused.”

Finding: SSH accepts password authentication, which is a real attack surface if the automated blocking in place were ever disabled or misconfigured. Classification: Medium (actively mitigated). Recommendation: move toward key-based SSH authentication for administrative access as defense-in-depth, so password brute-forcing is not viable even before fail2ban intervenes.

6. How the Three Tools Complement Each Other

Wireshark shows what actually crossed the wire — ground truth for confirming that the scan and brute-force traffic really happened as described, independent of any single tool's own self-reported output.

Nmap answers “what's exposed and how well is it configured” — a point-in-time inventory of services and their hardening state.

Hydra answers “can a specific exposed service actually be broken into” — turning a configuration finding (password auth permitted) into a tested outcome (no credentials recovered, and the attempt was blocked).

Together with the IDS/IPS response documented separately, these three tools cover the full loop this rubric area is built around: know what's on the network, know its weaknesses, prove or disprove exploitability, and confirm the network detects and reacts.

7. Rubric Mapping

Rubric Requirement	What Satisfies It	Where
1 Wireshark capture with analysis	assessment_capture.pcap on dc01 (enp0s8), spanning the scan and brute-force window, with filtered analysis of scan and SSH-negotiation traffic.	Section 3
1 network vulnerability scanner report	Nmap asset discovery + NSE vulnerability scan against 192.168.30.0/24 and dc01, with findings table and risk classification.	Section 4
1 network penetration testing tool output	Hydra SSH credential brute-force run against dc01, console output captured, outcome cross-referenced to the IPS response.	Section 5

8. Conclusion

This documentation satisfies the Utilize Network Security Tools rubric item with one Wireshark capture and analysis (recon and brute-force traffic patterns on dc01's interface), one network vulnerability scanner report (Nmap asset

discovery plus NSE vulnerability scan with classified findings), and one network penetration testing tool output (Hydra SSH brute-force run, no credentials recovered, blocked mid-run by the lab's IPS). All three are tied to the same timestamped incident documented in the Network Security Fundamentals report, giving a single coherent narrative across both rubric items.